Most of the flexibility of the JOSE and JWT standards is concentrated in the header, which is an additional JSON object that is included in the authentication tag and contains metadata about the JWT. For example, the following header indicates that the token is signed with HMAC-SHA-256 using a key with the given key ID:

```
{
         "alg": "HS256",    #A
         "kid": "hmac-key-1"    #B
}
```

#A The algorithm
#B The key identifier

While seemingly innocuous, the JOSE header is one of the more error-prone aspects of the specifications, which is why the code you have written so far does not generate a header and I often recommend that they are stripped when possible to create (non-standard) *headless JWTs*. This can be done by removing the header section produced by a standard JWT library before sending it and then recreating it again before validating a received JWT. Many of the standard headers defined by JOSE can open your API to attacks if you are not careful, as described in this section.

> **DEFINITION** A ***headless JWT*** is a JWT with the header removed. The recipient recreates the header from expected values. For simple use-cases where you control the sender and recipient this can reduce the size and attack surface of using JWTs but the resulting